

DOCUMENTAÇÃO DE ARQUITETURA CLOUD / DEVOPS

Responsável: Emanuel José Tenório Rodrigues

Data:

1. Introdução

Contexto

Uma empresa está realizando a migração de sua aplicação Web para a infraestrutura de nuvem da Amazon Web Services (AWS), buscando estruturar uma solução capaz de oferecer acesso externo à aplicação, organização dos componentes da solução e maior controle sobre comunicação e segurança dos recursos.

A aplicação possui três componentes principais: uma aplicação Web responsável pelo atendimento das requisições dos usuários, um banco de dados PostgreSQL utilizado para armazenamento persistente das informações e um serviço Redis destinado ao armazenamento temporário de dados utilizados pela aplicação.

Como requisito de segurança, a solução deverá separar os componentes da aplicação e dos dados em ambientes distintos, permitindo apenas as comunicações necessárias para o funcionamento adequado do sistema.

A arquitetura proposta deverá permitir que a aplicação seja acessível pela Internet, utilizando um Application Load Balancer (ALB) para distribuição das requisições entre as instâncias responsáveis pela execução da aplicação Web.

2. Objetivos da Arquitetura

A arquitetura tem como objetivo projetar uma solução em nuvem para hospedagem da aplicação Web, garantindo uma estrutura organizada, segura e preparada para crescimento futuro.

Os principais objetivos da solução são:

- Disponibilizar a aplicação Web na AWS com acesso externo por meio da Internet.
- Garantir separação adequada entre os componentes da aplicação e os componentes responsáveis pelo armazenamento de dados.
- Proteger os serviços de dados contra acessos externos não autorizados.
- Permitir comunicação controlada entre os diferentes componentes necessários ao funcionamento da aplicação.
- Estruturar uma solução que permita expansão futura conforme o crescimento da demanda.

A arquitetura também deve considerar boas práticas de segurança, garantindo que recursos que não necessitam de exposição direta à Internet não possuam acesso administrativo externo direto.

3. Requisitos da Solução

3.1 Requisitos Funcionais

A solução deverá atender aos seguintes requisitos funcionais:

- Disponibilizar uma aplicação Web acessível pela Internet.
- Utilizar um Application Load Balancer (ALB) para receber e distribuir as requisições destinadas à aplicação.
- Utilizar PostgreSQL como banco de dados para armazenamento persistente das informações da aplicação.
- Utilizar Redis para armazenamento temporário de informações utilizadas pela aplicação.
- Permitir que a aplicação Web consiga acessar os serviços PostgreSQL e Redis por meio da comunicação entre os ambientes definidos.

3.2 Requisitos Não Funcionais

A solução deverá atender aos seguintes requisitos não funcionais:

- Possuir capacidade de expansão futura conforme crescimento da aplicação.
- Garantir organização dos recursos em ambientes adequados conforme suas necessidades de comunicação.
- Permitir distribuição dos recursos considerando capacidade mínima de crescimento:
 - Sub-redes destinadas às instâncias da aplicação devem suportar pelo menos 20 instâncias.
 - Sub-redes destinadas aos serviços de dados devem suportar pelo menos 25 recursos, considerando serviços atuais e futuras expansões.

3.3 Requisitos de Segurança

A solução deverá possuir controles de segurança que garantam:

- Separação dos ambientes de aplicação e dados em redes distintas.
- Restrição de comunicação entre componentes, permitindo somente os acessos necessários ao funcionamento da aplicação.
- Proteção dos serviços PostgreSQL e Redis contra acesso direto pela Internet.
- Controle das comunicações utilizando regras específicas de segurança.
- Restrição de acesso administrativo direto pela Internet aos recursos que não necessitam desse tipo de exposição.

3.4 Requisitos de Disponibilidade e Escalabilidade

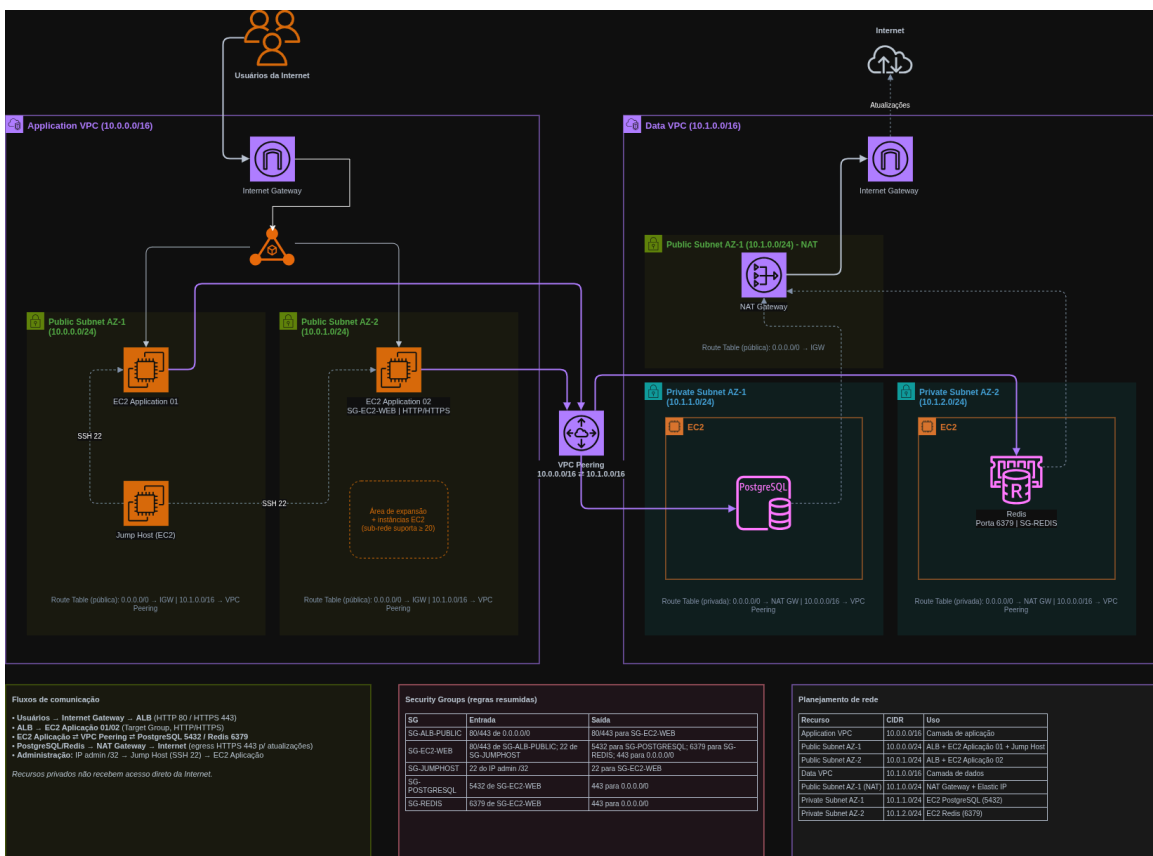
A solução deverá considerar:

- Distribuição da aplicação Web em múltiplas sub-redes públicas distintas.

- Utilização de um mecanismo de distribuição de requisições para suportar múltiplas instâncias da aplicação.
- Estrutura preparada para expansão futura dos recursos da solução.

4. Visão Geral da Arquitetura

A arquitetura proposta será composta por duas VPCs independentes: uma destinada à camada de aplicação e outra destinada aos serviços de dados. A comunicação entre os ambientes será realizada utilizando VPC Peering, permitindo somente os fluxos necessários entre a aplicação Web, o banco PostgreSQL e o serviço Redis.



5. Decisões Arquiteturais

1. Separação entre aplicação e dados em VPCs distintas

A arquitetura será composta de duas VPCs independentes, sendo uma destinada para aplicação e outra para dados, com o objetivo de reduzir o acoplamento entre os componentes, aumentar o isolamento de serviços críticos e permite aplicar controles de segurança específicos para cada camada.

2. Comunicação entre as VPCs através de VPC Peering

A comunicação entre a VPC de aplicação e VOC de dados será utilizando VPC Peering, visto que os serviços de dados não devem ser acessíveis via Internet,

então a aplicação desse método de comunicação é necessário para ter acesso aos dados armazenados.

3. Application Load Balancer para distribuição de carga entre as VPCs

A entrada da aplicação será realizada através de um ALB localizado na camada pública da VPC de aplicação. O objetivo é que o ALB será responsável por receber as requisições externas e distribuí-las entre as instâncias responsáveis pela aplicação web.

4. Distribuição da aplicação em múltiplas subnets públicas

As instâncias das aplicações serão distribuídas em duas subnets públicas distintas, a fim de permitir maior disponibilidade e futura escalabilidade.

5. Manter PostgreSQL e Redis em ambiente privado

O PostgreSQL e Redis serão executados em uma subnet privada com o objetivo de manter integridade e sigilo dos dados, visto que esses não podem ser expostos pela Internet.

6. Uso de Security Groups para controle de comunicação

O controle por regras específicas e liberação estrita de portas reduz acesso indevido e segue o princípio de menor privilégio.

7. Controle rotas específicas

Cada subnet possuirá tabelas de rotas específicas e adequadas para acesso aos caminhos de Internet, aplicação e dados.

8. Bloqueio de SSH direto às instâncias

As instâncias não necessitam de acesso direto via Internet, visto que o acesso deve ocorrer através de Jump Host, a fim de evitar ataques e uso indevido dos recursos computacionais.

6. Planejamento de Rede

6.1 Estrutura de Rede

A arquitetura de rede será composta por duas VPCs independentes, separando a camada de aplicação da camada de dados. A primeira VPC será responsável pela execução da aplicação Web, contendo o ALB e as instâncias responsáveis pelo processamento das requisições dos usuários. A segunda VPC será destinada aos serviços de dados, contendo o banco PostgreSQL e o serviço Redis, mantendo esses componentes isolados da exposição direta à Internet. A comunicação entre as duas VPCs será realizada através de VPC Peering, permitindo somente os fluxos necessários entre a aplicação e os serviços de dados.

- Estrutura das VPCs
 - Application VPC

- Tem como objetivo hospedar os componentes responsáveis pelo atendimento das requisições externas da aplicação que através da ALB terá o tráfego distribuído entre as múltiplas subnets públicas. Isso permite maior disponibilidade e expansão futura.
- Componentes:
 - Application Load Balancer (ALB);
 - Instâncias EC2 da aplicação web;
 - JumpHost para acesso administrativo.
- Subnets:
 - Public Subnet AZ-1 → Rede pública para hospedar instância EC2;
 - Public Subnet AZ-2 → Rede pública para hospedar instância EC2.
- Data VPC
 - Hospeda os componentes e serviços responsáveis pelo armazenamento persistente e temporário dos dados da aplicação. Como os serviços dessa VPC não devem ter acesso à Internet, então será utilizada uma subnet privada, garantindo isolamento
 - Componentes:
 - Instâncias EC2;
 - PostgreSQL;
 - Redis.
 - Subnet:
 - Private Subnet → Rede privada para hospedar as instâncias EC2 com os serviços de armazenamento PostgreSQL e Redis.
- Comunicação entre Redes

A comunicação seguirá o seguinte fluxo:

Internet User → ALB → EC2 Application → VPC Peering → PostgreSQL/Redis

A aplicação web terá acesso controlado via security groups com as seguintes portas: 5432 (PostgreSQL) e 6379 (Redis).

6.2 Planejamento de Endereços IP

- Definição dos blocos CIDR das VPCs

Os blocos de endereçamento foram definidos de forma que não exista sobreposição entre as redes, permitindo a comunicação futura através de VPC Peering. Será usado o bloco /16 nas subnets para disponibilizar grande quantidade de endereços IP e uma futura expansão da arquitetura.

 - Application VPC

- CIDR: 10.0.0.0/16
- Hospeda camada de aplicação
- Data VPC
 - CIDR: 10.1.0.0/16
 - Hospeda camada de dados

7. Componentes da Arquitetura

7.1 Virtual Private Cloud (VPC)

- Objetivo: Criar ambientes isolados para separar a camada de aplicação da camada de dados.
- Descrição: A solução utiliza duas VPCs independentes. A Application VPC hospeda os componentes responsáveis pelo atendimento das requisições dos usuários, enquanto a Data VPC hospeda os serviços de armazenamento da aplicação.
- Configurações principais:
 - Application VPC: 10.0.0.0/16
 - Data VPC: 10.1.0.0/16
 - Comunicação entre VPCs utilizando VPC Peering.
- Dependências:
 - Internet Gateway
 - NAT Gateway
 - Route Tables
 - Security Groups
 - VPC Peering
- Justificativa da utilização: A separação das redes aumenta o isolamento dos serviços críticos e permite aplicar regras de segurança específicas para cada ambiente.
- Passos de criação/configuração:
 - Criar as duas VPCs com blocos CIDR distintos.

- Criar as subnets públicas e privadas.
 - Configurar tabelas de rotas.
 - Configurar comunicação através do VPC Peering.
- Validações realizadas:
 - Confirmado que não existe sobreposição entre os blocos CIDR.
 - Confirmada comunicação entre as VPCs através das rotas configuradas.

7.2 Application Load Balancer (ALB)

- Objetivo: Receber requisições externas e distribuí-las entre as instâncias da aplicação Web.
- Descrição: O ALB será disponibilizado nas subnets públicas da Application VPC e encaminhará as requisições para as instâncias EC2 responsáveis pela execução da aplicação.
- Configurações principais:
 - Associado às duas subnets públicas.
 - Distribuição entre duas instâncias EC2.
 - Comunicação HTTP/HTTPS.
- Dependências:
 - Internet Gateway.
 - Target Group com as instâncias EC2.
 - Security Group do ALB.
- Justificativa da utilização: Permite distribuição de carga, disponibilidade e expansão futura da aplicação.
- Passos de criação/configuração:
 - Criar o Load Balancer.
 - Associar às subnets públicas.
 - Criar Target Group.

- Registrar as instâncias EC2.
- Configurar regras de encaminhamento.
- Validações realizadas:
 - Teste de recebimento de requisições externas.
 - Validação da distribuição entre as instâncias.

7.3 Instâncias EC2 da Aplicação Web

- Objetivo: Executar a aplicação Web responsável pelo processamento das requisições.
- Descrição: Serão utilizadas duas instâncias EC2 distribuídas em subnets públicas distintas para aumentar disponibilidade.
- Configurações principais:
 - EC2 Application 01: Public Subnet AZ-1.
 - EC2 Application 02: Public Subnet AZ-2.
- Dependências:
 - ALB.
 - Security Groups.
 - VPC Application.
- Justificativa da utilização: Permite funcionamento distribuído da aplicação e suporta crescimento futuro.
- Validações realizadas:
 - Instâncias acessíveis através do ALB.
 - Comunicação com serviços de dados validada.

7.4 PostgreSQL

- Objetivo: Armazenar permanentemente os dados utilizados pela aplicação.
- Descrição: O PostgreSQL ficará hospedado na Data VPC em ambiente privado, sem exposição direta à Internet.
- Configurações principais:

- Porta: 5432.
- Acesso permitido somente pela camada de aplicação.
- Dependências:
 - Data VPC.
 - Security Group.
 - VPC Peering.
- Justificativa da utilização: Mantém os dados protegidos e acessíveis somente pelos componentes necessários.

7.5 Redis

- Objetivo: Armazenar informações temporárias utilizadas pela aplicação.
- Descrição: O Redis ficará em ambiente privado junto à camada de dados.
- Configurações principais:
 - Porta: 6379.
 - Comunicação restrita com a aplicação Web.
- Dependências:
 - Data VPC.
 - Security Group.
 - VPC Peering.
- Justificativa da utilização: Permite armazenamento temporário com isolamento de segurança.

8. Comunicação entre Componentes

Fluxo externo:

Usuário → Internet Gateway → Application Load Balancer → Instâncias EC2.

Fluxo interno:

Aplicação Web → VPC Peering → PostgreSQL e Redis.

Portas utilizadas:

- HTTP/HTTPS: comunicação usuário e ALB.
- 5432: PostgreSQL.
- 6379: Redis.

A comunicação será controlada por Security Groups, permitindo somente os fluxos necessários.

9. Segurança

Os Security Groups serão utilizados para controlar a comunicação entre os componentes da arquitetura, permitindo somente os fluxos necessários para execução da aplicação. Cada camada possui um grupo de segurança específico, evitando exposição desnecessária dos serviços internos. Todos os SG vem como prefixo default da AWS.

- Security Group do ALB
 - Nome: SG-ALB-PUBLIC
 - Tem como objetivo controlar o acesso externo à aplicação, permitindo requisições via internet com protocolo HTTP e HTTPS. O ALB será o único componente visivelmente exposto a internet
 - Regras de Entrada:

Protocolo	Porta	Origem
HTTP	80	0.0.0.0/0 → qualquer origem IPv4
HTTPS	443	0.0.0.0/0 → qualquer origem IPv4

- Regras de Saída:

Protocolo	Porta	Destino
HTTP	80	SG-EC2-WEB
HTTPS	443	SG-EC2-WEB

- Security Group das Instâncias EC2
 - Nome: SG-EC2-WEB

- Controla os acessos às instâncias responsáveis pela execução da aplicação web, visto que todos os acessos via Internet devem ocorrer através do ALB.

- Regras de Entrada:

Protocolo	Porta	Origem
HTTP	80	SG-ALB-PUBLIC
HTTPS	443	SG-ALB-PUBLIC
SSH	22	SG-JUMPHOST

- Regras de Saída:

Protocolo	Porta	Destino
PostgreSQL (TCP)	5432	SG-POSTGRESQL
Redis (TCP)	6379	SG-REDIS
HTTPS	443	0.0.0.0/0 → qualquer origem IPv4

- Security Group do JumpHost

- Nome: SG-JUMPHOST
- Permite acesso administrativo às instâncias EC2 sem disponibilizar SSH diretamente pela Internet
- Regras de Entrada:

Protocolo	Porta	Origem
SSH (TCP)	22	IP administrativo autorizado/32

- Regras de Saída:

Protocolo	Porta	Destino
SSH (TCP)	22	SG-EC2-WEB

- Security Group do PostgreSQL

- Nome: SG-POSTGRESQL
- Protege o banco de dados permanente contra acessos externos
- Regras de Entrada:

Protocolo	Porta	Origem
PostgreSQL (TCP)	5432	SG-EC2-WEB

- Regras de Saída:

Protocolo	Porta	Destino
HTTPS (TCP)	443	0.0.0.0/0

- Security Group do Redis

- Nome: SG-REDIS
- Controla acesso ao serviço Redis utilizado para armazenamento temporário da aplicação.
- Regras de Entrada:

Protocolo	Porta	Origem
Redis (TCP)	6379	SG-EC2-WEB

- Regras de Saída:

Protocolo	Porta	Origem
HTTPS (TCP)	443	0.0.0.0/0

10. Controle de Acesso

O acesso aos recursos será realizado conforme necessidade operacional.

Políticas:

- Usuários administrativos terão permissões controladas.
- Acesso às instâncias será realizado através do Jump Host.
- Serviços internos não possuirão acesso administrativo externo.

11. Rotas e Conectividade

Application VPC:

- Subnets públicas utilizam Internet Gateway para comunicação externa.
- Rotas internas direcionam comunicação para a Data VPC através do VPC Peering.

Data VPC:

- Rotas permitem somente comunicação necessária com a Application VPC.
- Serviços internos permanecem protegidos contra acesso externo.

12. Escalabilidade e Disponibilidade

A arquitetura suporta crescimento através de:

- Duas subnets públicas distintas para a aplicação.
- Distribuição de requisições pelo ALB.
- Possibilidade de adicionar novas instâncias EC2.
- Blocos CIDR preparados para expansão futura.

13. Testes e Validação

Testes realizados:

- Validação de acesso externo através do ALB.
- Teste de comunicação entre aplicação e banco.
- Teste de comunicação entre aplicação e Redis.
- Validação das regras de Security Groups.
- Validação das rotas entre VPCs.